

INSTITUTO NACIONAL DE TELECOMUNICAÇÕES

TP546

PROBLEMAS DE SEGURANÇA EM REDES IoT

Ataques de Negação de Serviço e Medidas de Proteção

ANDERSON REIS RUFINO MARINS

E

EDSON CLAITON DA SILVA JUNIOR

SANTA RITA DO SAPUCAÍ

2026

ANDERSON REIS RUFINO MARINS
E
EDSON CLAITON DA SILVA JUNIOR

PROBLEMAS DE SEGURANÇA EM REDES IoT

Ataques de Negação de Serviço e Medidas de Proteção

Relatório apresentado à disciplina de *TP546*,
como requisito parcial para avaliação.

SANTA RITA DO SAPUCAÍ
2026

Sumário

1	Introdução	2
2	Segurança em Redes IoT	2
3	Ataques de Negação de Serviço em IoT	3
4	Exemplo de Ataque: Esgotamento de Conexões	5
4.1	Funcionamento do laboratório	5
4.2	Representação do laboratório	6
4.3	Indicadores observados	6
5	Consequências de um Ataque de DoS contra IoT	7
6	Medidas de Proteção	7
6.1	Segmentação da rede	8
6.2	Limitação de conexões e requisições	8
6.3	Firewall	9
6.4	Atualização de software e firmware	9
6.5	Senhas e autenticação	10
6.6	Monitoramento	10
6.7	Resiliência	10
7	Proposta de Arquitetura Segura	11
8	Importância da Segurança desde o Desenvolvimento	11
9	Conclusão	12

1 Introdução

A Internet das Coisas, conhecida pela sigla IoT (*Internet of Things*), corresponde ao conjunto de dispositivos físicos conectados a redes de comunicação e capazes de coletar, processar e transmitir informações. Câmeras de segurança, fechaduras eletrônicas, sensores industriais, relógios inteligentes, eletrodomésticos, sistemas de automação residencial e equipamentos médicos são alguns exemplos de dispositivos que podem fazer parte de uma rede IoT.

A utilização desses dispositivos proporciona diversos benefícios, como automação de tarefas, monitoramento remoto, redução de custos e coleta de dados em tempo real. Entretanto, a expansão da IoT também aumentou a superfície de ataque disponível para agentes mal-intencionados. Muitos dispositivos possuem recursos computacionais limitados, sistemas operacionais simplificados, configurações inadequadas ou permanecem conectados à Internet durante longos períodos.

Entre os problemas de segurança associados à IoT estão senhas fracas ou padrão, serviços de rede desnecessários, interfaces inseguras, ausência de atualizações, componentes de software desatualizados, configurações inseguras e falhas na proteção das comunicações.

A OWASP apresenta diversos riscos relacionados à segurança de dispositivos IoT, incluindo serviços de rede inseguros, que podem aumentar a exposição dos equipamentos a ataques e comprometer sua disponibilidade [1].

Este relatório aborda especificamente o problema dos **ataques de negação de serviço** (*Denial of Service – DoS*) em redes IoT.

Inicialmente, será apresentado o funcionamento desse tipo de ataque. Em seguida, será descrito um exemplo que pode ser reproduzido de maneira controlada em um laboratório. Por fim, serão apresentadas medidas técnicas e administrativas que podem ser utilizadas para reduzir os riscos.

2 Segurança em Redes IoT

A segurança de uma rede IoT não depende exclusivamente do dispositivo. Pois, envolve o equipamento, a rede, os serviços utilizados, os aplicativos, servidores em nuvem e mecanismos utilizados para administrar os dispositivos.

O National Institute of Standards and Technology (NIST) destaca que a segurança dos dispositivos IoT deve ser considerada durante sua aquisição, implantação e utilização, levando em conta os riscos introduzidos pelo dispositivo no sistema como um todo [2].

Uma característica importante das redes IoT é a grande quantidade de dispositivos potencialmente conectados. Em uma organização, por exemplo, podem existir centenas ou milhares de sensores e equipamentos. Logo, se esses dispositivos forem configurados de maneira inadequada, uma vulnerabilidade aparentemente pequena poderá atingir uma quantidade significativa de equipamentos.

Entre os problemas mais comuns encontram-se:

- utilização de senhas padrão ou facilmente descobertas;
- serviços de rede desnecessários habilitados;
- ausência de mecanismos seguros de atualização;
- utilização de componentes de software desatualizados;
- falta de segmentação da rede;
- comunicação sem criptografia adequada;
- configurações padrão inseguras;
- ausência de mecanismos de monitoramento;
- recursos computacionais limitados;
- dificuldade de manutenção e atualização de dispositivos antigos.

A OWASP classifica os serviços de rede inseguros como um dos principais riscos para dispositivos IoT [1], tais como serviços desnecessários ou inseguros, especialmente quando expostos à Internet, podem afetar a confidencialidade, integridade e disponibilidade do equipamento.

Neste trabalho, será dada ênfase à disponibilidade, uma vez que ataques de negação de serviço procuram impedir ou dificultar que usuários legítimos utilizem determinado serviço.

3 Ataques de Negação de Serviço em IoT

Um ataque de negação de serviço, conhecido como DoS (*Denial of Service*), tem como objetivo fazer com que um sistema, dispositivo ou serviço fique indisponível ou apresente uma degradação significativa de desempenho para usuários legítimos.

Em condições normais, um dispositivo IoT recebe requisições, processa essas requisições e devolve respostas. Um ataque de DoS explora essa relação fazendo com que o

dispositivo precise processar uma quantidade anormal de requisições ou mantenha recursos ocupados por conexões que não representam usuários legítimos.

Uma representação simplificada pode ser observada na Figura 1.



Figura 1: Funcionamento normal de uma comunicação IoT.

Durante um ataque de DoS, uma grande quantidade de requisições pode ser direcionada ao dispositivo:

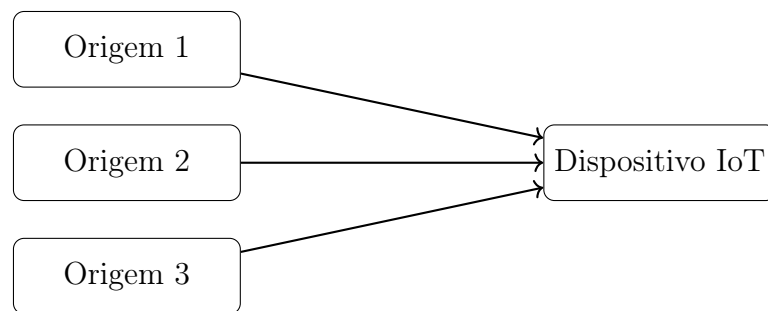


Figura 2: Representação simplificada de múltiplas requisições contra um dispositivo IoT.

Os recursos consumidos podem incluir:

- processamento da CPU;
- memória RAM;
- conexões de rede;
- largura de banda;
- tabelas de conexões;
- armazenamento destinado a registros;
- recursos de aplicações específicas.

Em redes IoT, o problema pode ser agravado pela capacidade limitada de determinados equipamentos. Portanto, um computador convencional pode possuir recursos suficientes para suportar uma quantidade elevada de conexões, enquanto um sensor ou equipamento embarcado pode possuir memória e capacidade de processamento bastante reduzidas.

Além do DoS realizado contra um único equipamento, existe o DDoS (*Distributed Denial of Service*). Nesse caso, diversos dispositivos ou computadores podem participar simultaneamente da geração de tráfego ou requisições contra determinado alvo.

A norma ETSI EN 303 645, voltada à segurança de dispositivos IoT de consumo, apresenta requisitos relacionados à resiliência dos dispositivos e serviços diante de situações que possam causar indisponibilidade e inclui recomendações relacionadas à mitigação de ataques DDoS [4].

4 Exemplo de Ataque: Esgotamento de Conexões

Para demonstrar o problema de maneira segura, pode-se criar um laboratório isolado contendo um dispositivo IoT simulado ou um pequeno servidor que represente um sensor.

O ambiente pode ser composto por:

- um computador representando o dispositivo IoT;
- um computador separado representando o cliente;
- uma rede de laboratório isolada;
- um serviço simples simulando uma aplicação IoT;
- ferramentas de monitoramento de CPU, memória e conexões.

O objetivo não é atacar um equipamento real, mas observar como o aumento controlado de conexões pode afetar o funcionamento de um serviço.

4.1 Funcionamento do laboratório

O procedimento pode ser dividido nas seguintes etapas:

1. Iniciar o serviço IoT simulado.
2. Registrar o comportamento normal do dispositivo.
3. Medir utilização de CPU, memória e conexões.
4. Gerar uma quantidade controlada de conexões a partir de uma segunda máquina.
5. Aumentar gradualmente a quantidade de conexões.
6. Registrar o tempo de resposta do serviço.

7. Interromper a geração de carga.
8. Observar o tempo necessário para a recuperação do serviço.

A atividade deve permanecer restrita ao ambiente de laboratório.

Não se faz necessário utilizar endereços IP públicos ou equipamentos pertencentes a terceiros. Dessa maneira, é possível demonstrar o conceito de negação de serviço sem produzir impacto em sistemas reais.

4.2 Representação do laboratório

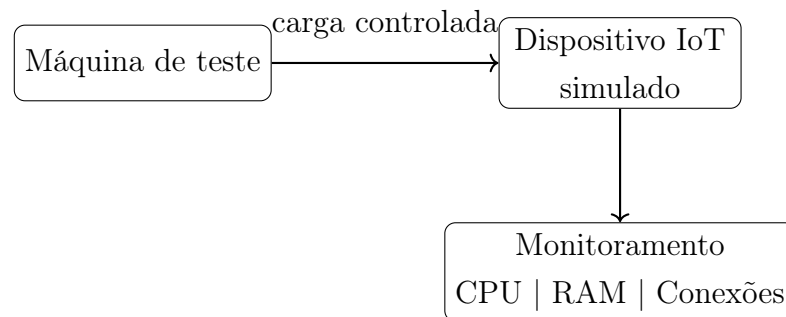


Figura 3: Ambiente de laboratório para análise de negação de serviço.

4.3 Indicadores observados

Durante o experimento, podem ser coletados dados como:

Tabela 1: Indicadores para avaliação do experimento

Indicador	Situação normal	Durante carga elevada
CPU	Utilização baixa ou moderada	Pode aumentar significativamente
Memória	Estável	Pode aumentar
Conexões	Quantidade limitada	Quantidade elevada
Tempo de resposta	Normal	Pode aumentar
Disponibilidade	Normal	Pode ocorrer degradação
Recuperação	Não aplicável	Pode exigir encerramento das conexões

Os resultados dependem das características do equipamento e da configuração do serviço. Portanto, os valores obtidos em um laboratório não devem ser generalizados para todos os dispositivos IoT.

5 Consequências de um Ataque de DoS contra IoT

As consequências de um ataque de negação de serviço dependem da finalidade do dispositivo.

Em uma residência, a indisponibilidade de uma câmera ou sistema de automação pode representar perda de monitoramento ou impossibilidade de utilizar determinada função remotamente.

Em um ambiente empresarial, a indisponibilidade de sensores pode interromper processos de monitoramento. Em uma indústria, por exemplo, a perda de comunicação com sensores pode afetar sistemas de supervisão e exigir procedimentos operacionais alternativos.

Há situações em que a indisponibilidade pode produzir consequências mais graves, tais como dispositivos IoT podem estar associados a sistemas de controle de acesso, equipamentos médicos ou processos industriais. Por isso, os requisitos de disponibilidade devem ser definidos considerando o impacto que uma interrupção pode causar.

Outro problema é a possibilidade de um dispositivo comprometido ser utilizado como parte de uma botnet. Equipamentos IoT com credenciais fracas, software vulnerável ou serviços inseguros podem ser comprometidos e posteriormente utilizados contra outros sistemas.

A utilização de credenciais únicas por dispositivo é uma das recomendações presentes na norma ETSI EN 303 645. Logo, a norma destaca que credenciais globais compartilhadas podem facilitar ataques automatizados em grande escala e contribuir para a formação de botnets [4].

6 Medidas de Proteção

A prevenção de ataques de negação de serviço exige uma combinação de medidas. Entretanto, não existe uma única configuração capaz de eliminar completamente o risco.

6.1 Segmentação da rede

Uma das medidas mais importantes é separar os dispositivos IoT de sistemas críticos e computadores de usuários.

Uma arquitetura simples pode ser representada da seguinte maneira:

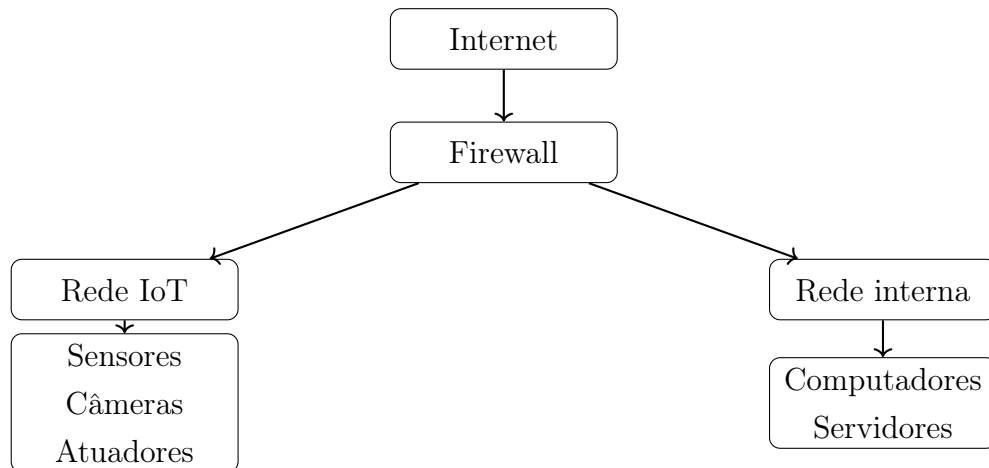


Figura 4: Exemplo de segmentação de uma rede IoT.

A segmentação reduz a possibilidade de que um dispositivo comprometido tenha acesso direto a todos os outros sistemas da organização.

Pode ser utilizada uma VLAN específica para equipamentos IoT, associada a regras de firewall que permitam somente as comunicações necessárias.

6.2 Limitação de conexões e requisições

Serviços de IoT devem estabelecer limites para o número de conexões simultâneas e para a quantidade de requisições que cada cliente pode realizar.

Esse mecanismo é conhecido como *rate limiting*, ou limitação de taxa.

Por exemplo, em vez de permitir que um cliente envie requisições indefinidamente, o serviço pode estabelecer limites e bloquear ou atrasar requisições que ultrapassem determinados parâmetros.

Também podem ser aplicados:

- limites de conexões simultâneas;
- tempo máximo para uma conexão;
- limites de requisições por segundo;

- bloqueio temporário de clientes suspeitos;
- filas para processamento;
- mecanismos de *backoff*.

Essas técnicas reduzem o impacto de cargas anormais.

6.3 Firewall

O firewall deve impedir que serviços desnecessários sejam acessíveis externamente.

Se um dispositivo IoT não precisa receber conexões diretamente da Internet, essas conexões devem ser bloqueadas.

Uma política de segurança adequada deve seguir o princípio de:

Permitir somente o que é necessário e bloquear o restante.

Essa abordagem diminui a superfície de ataque.

6.4 Atualização de software e firmware

A manutenção de firmware e software são fundamentais, vulnerabilidades conhecidas podem ser utilizadas por atacantes para obter acesso aos dispositivos.

A norma ETSI EN 303 645 estabelece requisitos relacionados a mecanismos seguros de atualização e recomenda que atualizações de segurança sejam disponibilizadas de maneira adequada. Além disso, recomenda-se mecanismos para verificar autenticidade e integridade das atualizações [4].

Portanto, as organizações devem:

- manter inventário dos dispositivos;
- acompanhar atualizações disponibilizadas pelos fabricantes;
- instalar correções de segurança;
- remover equipamentos sem suporte quando o risco for elevado;
- verificar a autenticidade das atualizações.

6.5 Senhas e autenticação

Credenciais padrão devem ser alteradas antes da utilização do equipamento.

Sempre que possível, devem ser utilizadas credenciais individuais, fortes e diferentes entre dispositivos. Logo, autenticação multifator pode ser aplicada aos sistemas de administração quando houver suporte.

A utilização de uma única senha compartilhada entre centenas de equipamentos aumenta o impacto de um eventual vazamento.

6.6 Monitoramento

O monitoramento permite identificar alterações no comportamento da rede.

Alguns indicadores importantes são:

- aumento repentino de conexões;
- aumento inesperado de tráfego;
- aumento da utilização da CPU;
- tentativas repetidas de autenticação;
- comunicação com endereços desconhecidos;
- reinicializações frequentes;
- indisponibilidade de serviços.

Sistemas de monitoramento e ferramentas de análise de logs podem gerar alertas quando determinados limites forem ultrapassados.

6.7 Resiliência

Além de tentar impedir o ataque, o dispositivo deve ser projetado para continuar funcionando parcialmente quando houver perda da comunicação.

A ETSI EN 303 645 recomenda mecanismos de resiliência e, quando apropriado, que determinadas funcionalidades locais possam continuar disponíveis durante uma perda de acesso à rede [4].

Por exemplo, uma fechadura inteligente poderia manter uma forma local de operação mesmo quando o servidor remoto estiver indisponível.

Essa abordagem reduz o impacto de ataques que causem indisponibilidade da infraestrutura de comunicação.

7 Proposta de Arquitetura Segura

Uma arquitetura de rede IoT mais resistente pode combinar diferentes mecanismos:

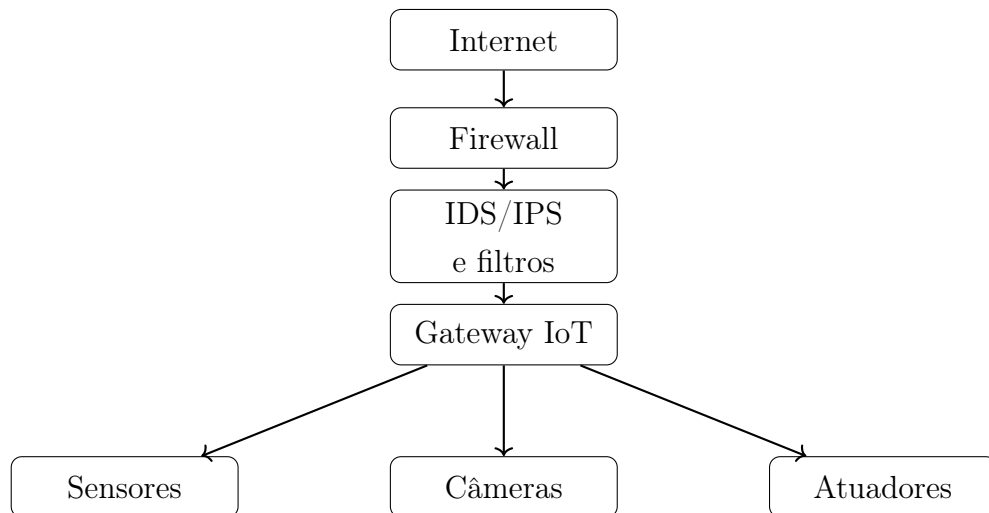


Figura 5: Arquitetura proposta para uma rede IoT.

Nessa arquitetura, o gateway pode funcionar como ponto intermediário entre os dispositivos e os serviços externos.

Isso permite concentrar algumas funções de segurança, como autenticação, filtragem, controle de acesso e monitoramento.

Os dispositivos devem possuir configurações individuais e utilizar somente os serviços necessários.

8 Importância da Segurança desde o Desenvolvimento

A segurança de IoT não deve ser tratada somente depois que um equipamento é colocado no mercado.

O NIST recomenda que os requisitos de segurança sejam considerados durante a aquisição e integração dos produtos IoT [2].

A abordagem permite identificar os controles necessários de acordo com os riscos do sistema.

Do ponto de vista do fabricante, isso significa considerar segurança durante todo o ciclo de vida:

**Projeto → Desenvolvimento → Testes → Implantação → Atualizações →
Descontinuação**

Durante os testes, podem ser realizados testes de carga e testes de segurança em ambiente controlado para verificar como o dispositivo reage a situações anormais.

É importante definir procedimentos para vulnerabilidades descobertas após a comercialização. Portanto, um dispositivo que não recebe atualizações durante toda a sua vida útil pode se tornar progressivamente mais vulnerável.

9 Conclusão

As redes IoT apresentam benefícios importantes, porém introduzem novos desafios de segurança. A grande quantidade de dispositivos, as limitações de processamento, a utilização de serviços de rede e a dificuldade de atualização podem aumentar a exposição a ataques.

Entre os diferentes problemas existentes, os ataques de negação de serviço são particularmente relevantes, pois, podem comprometer diretamente a disponibilidade dos dispositivos e serviços.

O exemplo apresentado neste relatório demonstra que um serviço IoT pode sofrer degradação quando recebe uma quantidade anormal de conexões ou requisições. Em um ambiente real, esse tipo de problema pode impedir usuários legítimos de acessar determinado equipamento ou serviço.

A proteção deve utilizar várias camadas. Segmentação de rede, firewalls, limitação de conexões, atualização de firmware, autenticação adequada, monitoramento e mecanismos de resiliência são algumas das principais medidas.

Além disso, a segurança deve ser considerada durante todo o ciclo de vida do dispositivo. Logo, organizações que utilizam IoT precisam manter inventário dos equipamentos, acompanhar vulnerabilidades e atualizações e estabelecer procedimentos para responder a incidentes.

Dessa forma, a segurança de uma rede IoT não depende apenas de impedir que um atacante explore uma vulnerabilidade. Portanto, é necessário limitar o impacto de um ataque caso ele aconteça e garantir que os serviços essenciais possam se recuperar rapidamente.

Referências

- [1] OWASP FOUNDATION.

OWASP Internet of Things Project.

Disponível em: <https://owasp.org/projects/internet-of-things>.

Acesso em: 2 out. 2026.

- [2] NIST – NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY.

FAGAN, M. et al.

IoT Device Cybersecurity Guidance for the Federal Government: Establishing IoT Device Cybersecurity Requirements – NIST SP 800-213.

Gaithersburg: NIST, 2021.

Disponível em: <https://csrc.nist.gov/pubs/sp/800/213/final>.

Acesso em: 2 out. 2026.

- [3] NIST – NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY.

MEGAS, K. et al.

IoT Device Cybersecurity Guidance for the Federal Government: IoT Device Cybersecurity Requirement Catalog – NIST SP 800-213A.

Gaithersburg: NIST, 2021.

Disponível em: <https://csrc.nist.gov/pubs/sp/800/213/a/final>.

Acesso em: 2 out. 2026.

- [4] ETSI – EUROPEAN TELECOMMUNICATIONS STANDARDS INSTITUTE.

EN 303 645 V3.1.3: Cyber Security for Consumer Internet of Things: Baseline Requirements.

2024.

Disponível em: https://www.etsi.org/deliver/etsi_en/303600_303699/303645/03.01.03_60/en_303645v030103p.pdf.

Acesso em: 2 out. 2026.